

Windows 10 CIS Benchmark Hardening Guide

This document provides a practical, step-by-step guide to configure a Windows 10 system in alignment with CIS (Center for Internet Security) Benchmark recommendations. The focus is on Level 1 hardening for secure and operationally usable environments.

Step 1 – Configure Account Policies

- 1 Open secpol.msc and navigate to Account Policies.
- 2 Set password history to 24.
- 3 Maximum password age: 60 days.
- 4 Minimum password length: 14 characters.
- 5 Enable password complexity.
- 6 Disable reversible encryption.

Step 2 – Account Lockout Policy

- 1 Lockout threshold: 5 attempts.
- 2 Lockout duration: 15 minutes.
- 3 Reset counter: 15 minutes.

Step 3 – Audit Policies

- 1 Enable auditing for logon events.
- 2 Enable account logon auditing.
- 3 Audit privilege use failures.
- 4 Audit policy changes.
- 5 Audit system events.
- 6 Enable process tracking.

Step 4 – User Rights Assignment

- 1 Allow local logon only to Administrators and Users.
- 2 Deny Guests local and network logon.
- 3 Restrict debug programs to Administrators.

Step 5 – Security Options

- 1 Disable built-in Administrator and Guest accounts.
- 2 Configure logon warning banner.
- 3 Set NTLMv2 authentication only.
- 4 Enable SMB signing.

Step 6 – Windows Firewall

- 1 Enable firewall for Domain, Private and Public.
- 2 Block inbound connections by default.
- 3 Enable firewall logging.

Step 7 – Microsoft Defender

- 1 Enable real-time protection.
- 2 Enable cloud protection.
- 3 Enable tamper protection.
- 4 Enable Attack Surface Reduction rules.

Step 8 – Disable Unnecessary Services

- 1 Disable Remote Registry.
- 2 Disable Xbox services.
- 3 Disable Print Spooler if not required.
- 4 Disable Bluetooth if unused.

Step 9 – Secure RDP

- 1 Enable Network Level Authentication.
- 2 Restrict RDP to authorized users.
- 3 Enable logging and monitoring.

Step 10 – Configure UAC

- 1 Set User Account Control to 'Always Notify'.

Step 11 – Disable SMBv1

- 1 Run PowerShell: `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`

Step 12 – Logging & Event Retention

- 1 Increase security log size.
- 2 Set retention to Do not overwrite.

Step 13 – BitLocker

- 1 Enable BitLocker for OS drive.
- 2 Use TPM + PIN if available.

Step 14 – Browser Hardening

- 1 Enable SmartScreen.
- 2 Block pop-ups.
- 3 Restrict extensions.

Step 15 – Validation

- 1 Use CIS CAT tool for compliance scanning.
- 2 Verify settings using auditpol and PowerShell.